MODULE 3

Evidence & Information Gathering

Certified Cyber Criminologist - Police / LEA Training

Samir Raja (CYBER07) | Cyber Crime Investigator & Offensive Security Researcher

What You Will Learn

Evidence wins cases only if it is **gathered legally and verified ruthlessly**. This module teaches both halves.

- **Police vs private investigator** - who can do what, and where the legal line sits
- **OSINT** - turning Google, social media and public records into intelligence
- **Email headers and WHOIS** - unmasking fake emails and fake websites
- **Verification** - the four tests every claim must pass before you trust it
- **Timelines and reports** - presenting the case so a judge understands it in one glance

Two Investigators, One Criminal

Two people hunt the same fraudster: a **police inspector** and a **private investigator**. Their powers are different - and so are their limits.

- The inspector can **demand bank records** and seize devices - the law stands behind him
- The private investigator cannot touch any of that - but may be **faster on open sources**
- In big cases they **work together**: companies hire private experts first, then hand over to police

Police vs Private Investigator

	Police Officer	Private Investigator
Records	Can demand bank/telecom records	Cannot demand any records
Seizure	Can seize devices legally	Cannot seize anything
Strength	Legal power, arrest	OSINT speed, agility
Limit	Every step must follow procedure	Must never pretend to be police

The Legal Boundary: One Rule for Both

Information gathered by breaking the law is useless - no matter how true it is. Memorise this before touching any tool.

- Evidence from **hacking** - entering accounts without permission - gets rejected in court
- Entering someone's device or inbox without consent is a **crime under the IT Act** - for you too
- A private investigator asking for data **pretending to be police** commits an offence
- At every step ask: **'Am I doing this legally?'** Doubt means stop and ask

Investigation in Five Steps

Step	What you do
1. Complaint	Hear the full story - screenshots, transaction IDs, everything preserved
2. Initial OSINT	Check the number, email, UPI ID, website on open sources
3. Formal complaint	cybercrime.gov.in, cyber police station, or the 1930 helpline
4. Technical evidence	Bank details, CDR - through legal notices, and IN TIME
5. Analysis and report	Connect everything into a timeline with conclusions

Step 1: Understand the Complaint Fully

Half of investigations fail at step one - because the **first story was heard carelessly**.

- Record **what happened, when, and how much was lost** - exact date, time, amount, platform
- Collect **everything** now: screenshots, chats, transaction IDs, the criminal's number or UPI ID
- Ask: did the victim click a link? Share an OTP? Install an app? Each answer **changes the investigation**
- Preserve originals **unedited** - cropped screenshots invite doubt later

Step 2: Initial OSINT - Before Any Notice

OSINT - **Open Source Intelligence** - means information anyone can legally find. Often the criminal's identity is sitting right here.

- Take the phone number, email ID, UPI ID or website and **search them openly** - Google, Truecaller, complaint sites
- A fraud number is often **already reported** by earlier victims - one search can confirm the pattern
- Check the email on **HaveIBeenPwned** - was it in a data leak? That explains how the criminal got it
- This step costs nothing, needs no notice, and **frequently cracks the case open**

OSINT Tools Every Investigator Uses

These tools are **completely legal** - the information is already public. The investigator's edge is using them **methodically**.

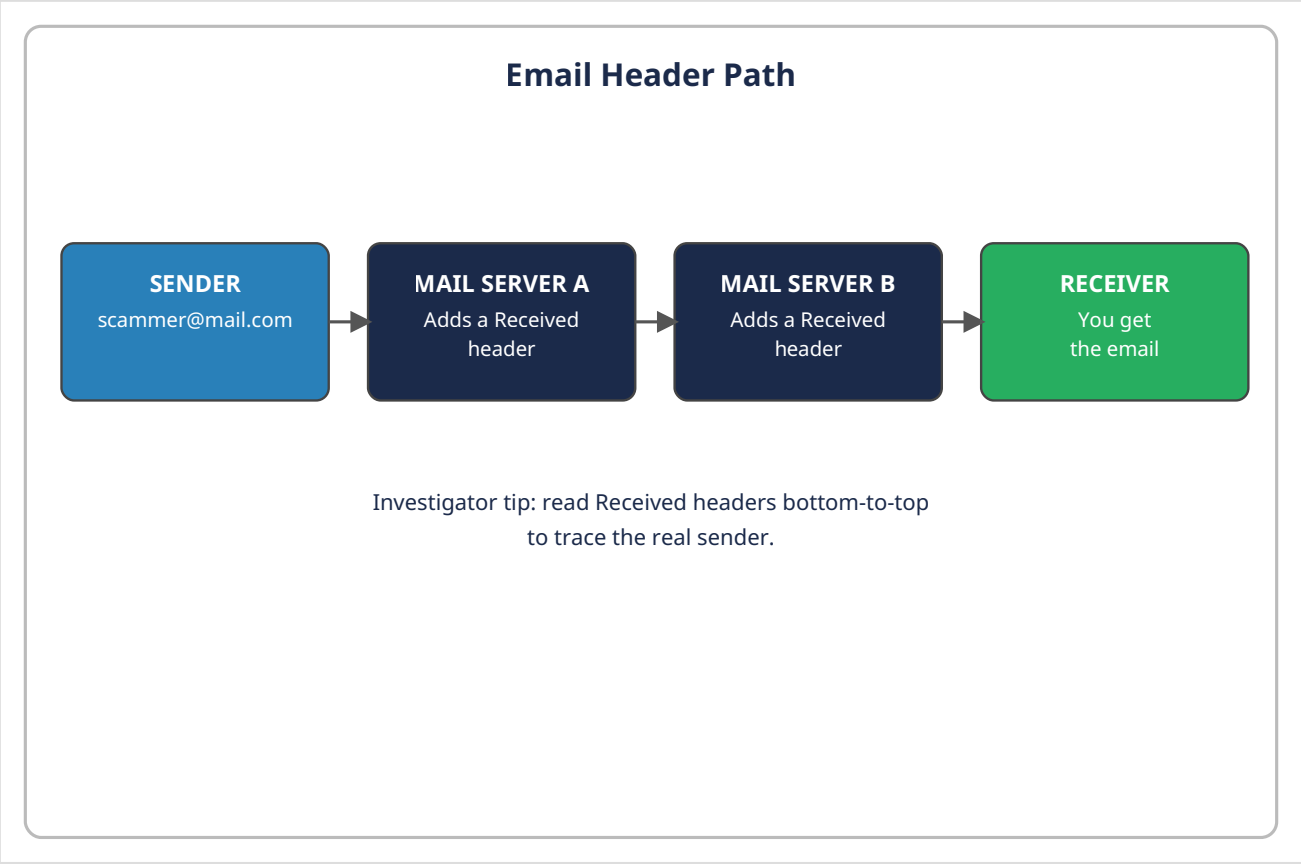
- **Google operators** - site:, quotes, filetype: - find what normal searches miss
- **Truecaller** - a name hint for a number. Direction only, **never evidence** - user-entered data
- **HaveIBeenPwned** - check if an email or phone appeared in known data breaches
- **Reverse image search** - Google Images or TinEye: where else has this photo been used?

Google Dorking: An Investigator's Eye

Google is not a question box - it is a **search weapon**. Four operators change everything:

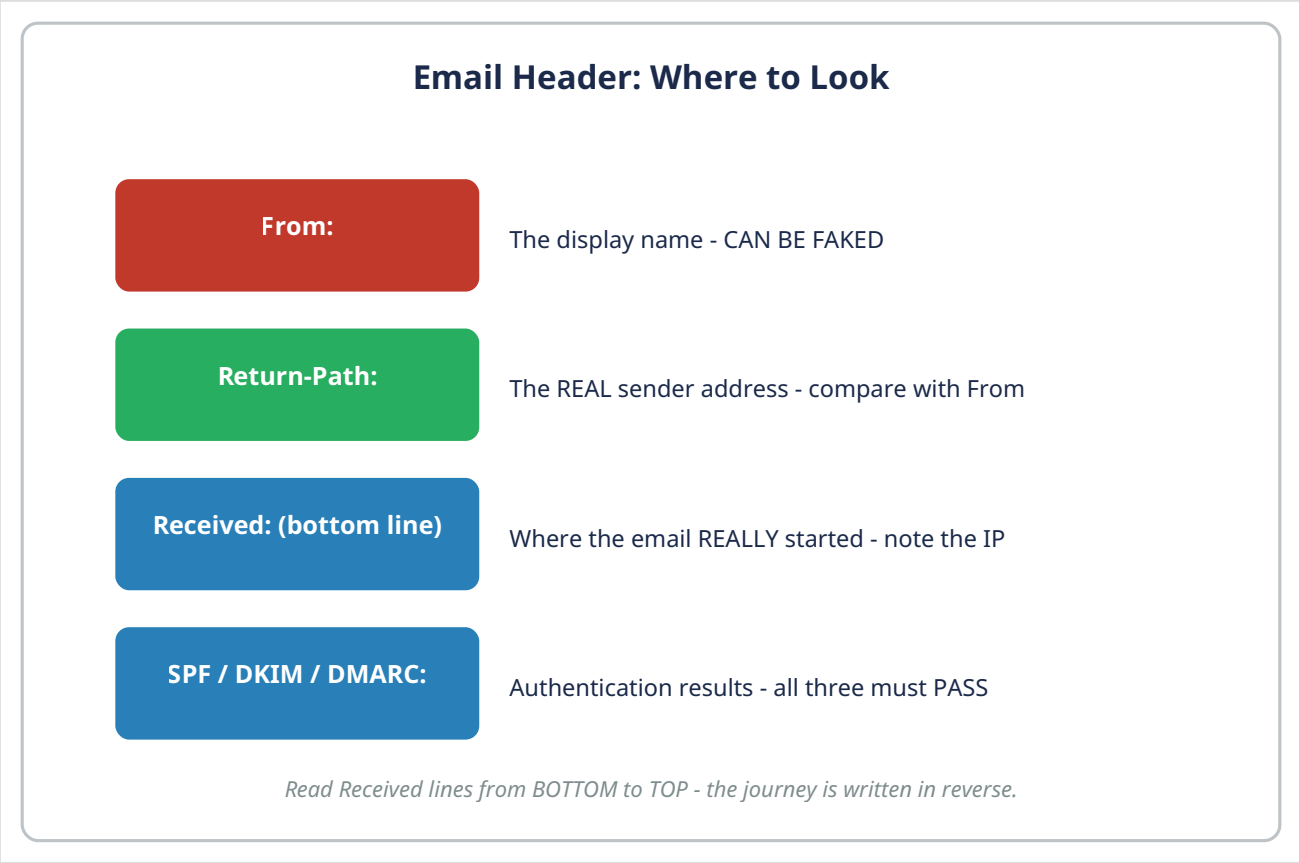
- **site:** - site:facebook.com "98XXXXXXXX" - where has this number appeared on Facebook?
- **"quotes":** - "98XXXXXXXX" - exact match. A fraud number repeats across complaint sites
- **filetype:** - filetype:pdf "company name" - digs out documents, reports, leaked files
- **- (minus):** - cyber fraud -movie - removes noise so the real results surface

Email Header: The Hidden Travel History



- Every email carries a **hidden header** - the servers it passed through, in order
- Reading it is the **first step** in every fake-email investigation
- The **From** name you see can be faked in seconds - the header cannot

Reading the Header: Where to Look



- In Gmail: open the mail, click **three dots → Show original**
- **Received** lines are read **bottom to top** - the bottom line is where the journey started
- Practice only on **your own** email - never open someone else's

SPF, DKIM, DMARC: The Three Gatekeepers

In the header, the **Authentication-Results** line shows three pass/fail checks. All three should say **pass**.

- **SPF** - was the sending server **authorised** to send mail for that domain?
- **DKIM** - is the domain's **digital signature** on the email valid?
- **DMARC** - does the email pass the domain's own **policy**?
- Failures here mean the email is **not really from who it claims** - investigate further

Spotting Spoofing: Three Comparisons

Spoofing means **wearing someone else's name**. The header exposes it in three places:

- **From vs Return-Path:** From is the display name (easily faked); Return-Path is the real sender. Different domains = red flag
- **Reply-To:** fraudsters set this to their **real** address so your reply reaches them - check it
- **Message-ID:** every email's unique ID reveals the **actual sending server** - compare with the claimed domain
- One mismatch is suspicion. **Two mismatches are proof** of spoofing

WHOIS: Reading a Domain's History

Every domain has a **public birth certificate** - the WHOIS record. Fake websites almost always betray themselves here.

- Open **who.is** or **whois.com**, enter the domain - no account needed, completely legal
- Note four things: **creation date, registrar, registrant country, expiry date**
- A 'bank' website whose domain is **12 days old** is not a bank - it is a trap
- Never enter your details on the suspicious site itself - **only read the report**

WHOIS Red Flags of a Fake Website

Sign	Why it is suspicious
Domain days or weeks old	Real banks and companies own domains for **years**
Name mimics a brand (sbi-onlline)	Typosquatting - read the URL **letter by letter**
Unknown cheap registrar	Fraudsters buy domains in **bulk, cheap**
Owner fully hidden + domain is new	Alone it is normal; **with a new domain** it is an alarm

Social Media Clues: Reading Public Profiles

Criminals are human - they **show off online**. Their public profiles leak location, contacts and habits.

- **Profile photo:** run reverse image search. Same photo on ten profiles = fake profile
- **Friends and followers:** many accounts created the same day, similar names = a fake network
- **Old posts:** people guard new posts but **forget to delete old ones** - real identity hides there
- **Location tags and posting times:** build a map of where he was, and when he is active

The Public-Only Rule

You may look at what is **open to everyone**. The moment you cross into private space, you become the criminal.

- Creating a **false identity** to send friend requests is deceptive and legally dangerous
- Entering someone's inbox or account without permission is **hacking - an IT Act offence**
- An investigator **gathers evidence**; he does not break the law to get it
- If it needs a trick to access, **get a legal route** instead - or leave it

Phone, UPI ID, Email: First Checks

In fraud cases the criminal's number or UPI ID is often your **only starting clue**. Squeeze it dry:

- **UPI ID hint:** rahulsharma123@okhdfc suggests a name; the part after @ reveals the bank or app
- **Truecaller:** gives a name and location idea - but it is **user-entered**, so treat as direction, not evidence
- **HaveIBeenPwned:** was this email in a breach? Then advise the victim to **change passwords** everywhere
- **Number age test:** a brand-new number claiming to be 'bank customer care' is **lying** - real helplines are years old

Verification: Four Tests for Every Claim

Gathering information is half the work. **Verifying it is the other half** - and the half most investigators skip.

- **Test 1 - Match date and time:** victim says 2 PM, call log shows 2:03 PM. Match strengthens the statement
- **Test 2 - Cross-check:** the same fact from **two independent sources**. One source is a rumour; two are evidence
- **Test 3 - Check the pattern:** has this number been complained about before? Pattern means the same criminal
- **Test 4 - Check the motive:** does anyone benefit from a false complaint? Rule it out

Verification in Action: A Complete Example

A victim says: on 10 March at 2 PM, a 'bank officer' called and took his OTP. Watch the four tests work:

- **Date-time match:** the call log shows the same number calling at **2:03 PM** on 10 March - statement strengthened
- **Cross-check:** Truecaller shows the **same name** the victim mentioned - second source agrees
- **Pattern:** cybercrime.gov.in shows **two more complaints** on this number - one criminal, three victims
- No single proof alone - but **all four together** make a professional case

Rank Your Sources



- **Strongest:** government records, bank statements, telecom data, court judgments
- **Weakest:** anonymous forwards, unsourced claims, random tips
- **Rule:** a weak source must always be confirmed through a **strong** one

Four Traps of Wrong Information

Bad information does not just waste time - it can **frame an innocent person**. Know the four traps:

- **Trap 1 - Old information:** a five-year-old address is not today's address. Check the **date** of everything
- **Trap 2 - Same names:** thousands share a name. Never identify by name alone - match phone, email, photo
- **Trap 3 - Deliberate lies:** the criminal **himself** spreads wrong info - fake profiles, false locations
- **Trap 4 - Half-truths:** more dangerous than full lies. Never conclude from **one screenshot** - see full context

Building an Investigation Timeline

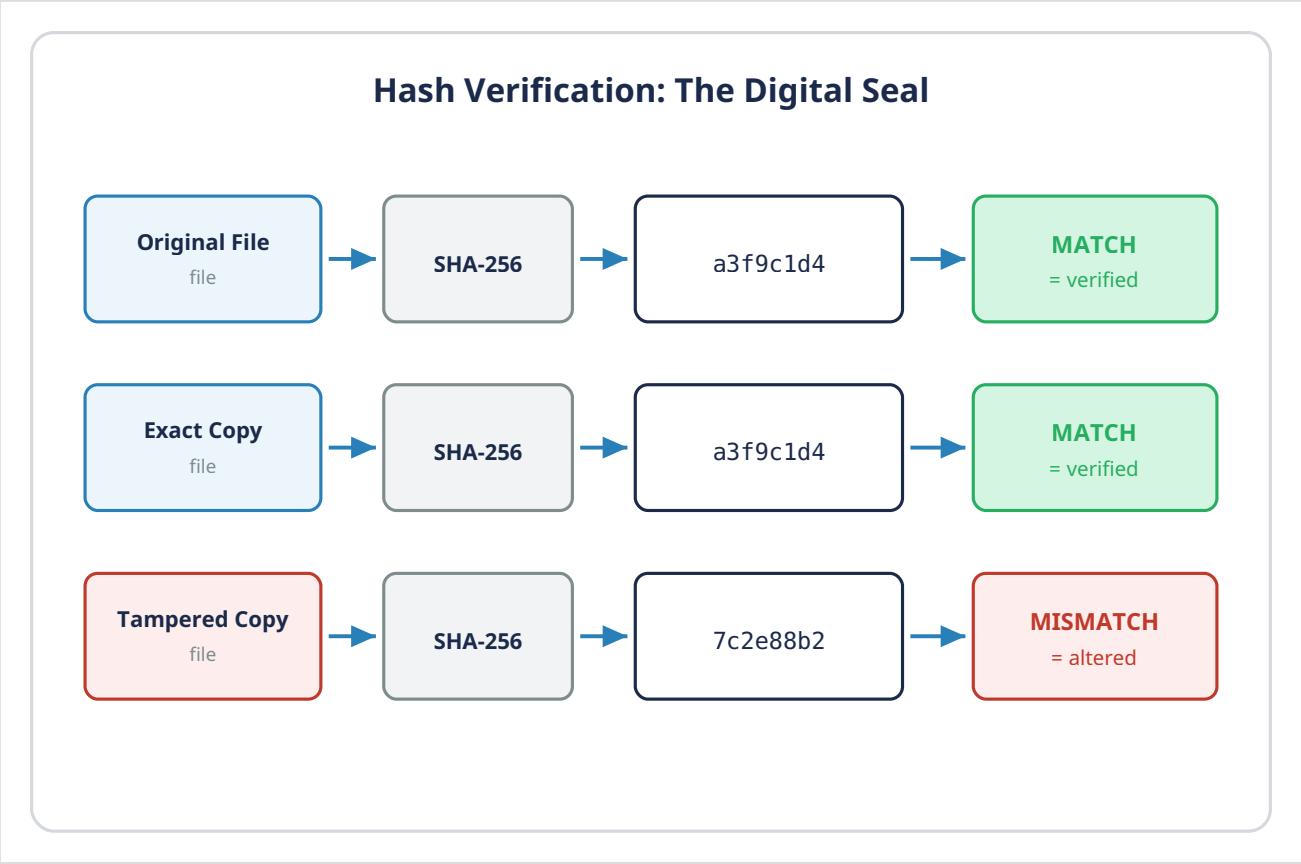
A timeline arranges every event in **date-time order**. It turns a pile of papers into the **story of the crime**.

- **Collect all dates:** from the complaint, screenshots, call logs, transaction receipts - every source
- **Order them oldest to newest**, with the **source** written against every entry
- **Find the gaps:** no information between 10 and 15 March? That gap is your next investigation
- A judge understands the whole case in **one glance** at a timeline - it is your most powerful exhibit

Timeline: A Worked Example

Date and time	Event	Source
08-03, 11:00 AM	Fraudster called the victim	Call log
08-03, 11:20 AM	Victim clicked the phishing link	Victim's statement
08-03, 11:25 AM	Rs 50,000 withdrawn	Bank statement
08-03, 02:00 PM	Victim called 1930	1930 ticket

Hash and Chain of Custody



- Every transfer recorded: **who, when, why** - no blank rows in the register
- The **hash** proves the digital file never changed between seizure and court
- Together they answer the court's hardest question: **'Is this evidence genuine?'**

Getting Records the Legal Way



- Write **what** you need, **which case**, **which period** - plus a deadline
- Request **early**: companies delete old data within months
- An incomplete demand gets **incomplete** information

Writing the Investigation Report

The report is your **final product**. A brilliant investigation with a confusing report still loses.

- **Title and case number** - which case, when it started. **Summary** - the whole story in two or three lines
- **Facts in date order** - every fact paired with its source. No source, no fact
- **Analysis** - what the facts prove about the criminal's method. **Evidence list** - what was found, where it is kept
- **Recommendations** - what action next. Write in **clear language**; explain every technical term

Private Investigator: Rules of the Trade

Private investigation is a profession - and professions have **ethics that protect you**.

- **Never impersonate police** to get information. State your real identity, always
- **Never access a device** without permission - that is hacking, whatever your intentions
- Keep a **complete record** and give the client a written report - your answer if questioned tomorrow
- In sensitive cases - blackmail, domestic disputes - the **victim's privacy comes first**

Real Case: Sulli Deals (2021)

An app 'auctioned' photos of Muslim women posted without consent. Delhi Police built the case **one verified link at a time**.

- Investigators connected **social media posts, app store records and payment information** - each link verified, no rushing
- Open-source clues led to **real identities and arrests** - OSINT done professionally, not recklessly
- **Lesson:** verified open-source information is not 'internet gossip' - it is evidence that arrests people
- Source The Hindu

Real Case: Bulli Bai (2022)

Months later, a copycat app surfaced. Mumbai's cyber cell showed **how fast good technique works**.

- Police connected the app's **GitHub records, social media accounts and technical clues** to identify the accused
- **Arrests in January 2022** - weeks, not years - because every digital trail was followed systematically
- **Lesson:** criminals repeat methods. Learn the method once, and the **next case solves faster**
- Source The Indian Express

Your Turn: Labs in This Module

Information gathering is learned **with your hands**, not your eyes. Chapter 3 has four labs:

- **Lab 1:** Email header analysis - extract the real sender IP, check SPF, DKIM, DMARC, catch spoofing
- **Lab 2:** WHOIS check - judge a domain by its age, registrar and registrant country
- **Lab 3:** Chain-of-custody form - fill it with zero blank rows, using your own pen drive as mock evidence
- **Lab 4:** Hash of a copy - prove with SHA-256 that your copy is a true copy

Key Takeaways

- **OSINT is legal** - public information, gathered methodically, is a superpower
- Read email headers **bottom to top**; judge websites by **WHOIS age**, not looks
- **Verify everything** - match dates, cross-check sources, check patterns and motives
- Weak sources must be confirmed through **strong sources** - never act on one forward
- The **timeline** is your most powerful exhibit; the **report** is your final product
- Stay inside the law - **illegally gathered information is worthless** in court

Review Questions

- 1. A private investigator offers to 'get' a suspect's bank statement for you. Explain exactly why accepting it endangers your whole case.
- 2. An email claims to be from your bank. Walk through the header checks you would run, in order, before trusting it.
- 3. A WHOIS report shows a 9-day-old domain, hidden owner, cheap registrar, mimicking a bank's name. Build the argument that it is fraudulent.
- 4. Two witnesses give conflicting times for the same call. Which verification tests do you apply, and in what order?
- 5. Why is a timeline more persuasive to a judge than a pile of screenshots? What makes a timeline entry trustworthy?

NEXT: MODULE 4

Techniques of Police & Investigation Agencies

Portals, CDR, BNSS notices, Zero FIR & coordination